



Estrategia de calidad, seguridad y despliegue

Plan de verificación para los 27 endpoints administrativos

PLANIFICACIÓN DE FASE 1

Proyecto	Aprueba Administración Backend
Equipo	Tsung-Hao Liu · Catalina Yanara Padilla Astudillo · Felipe Antonio Rojas Riffo
Alcance	27 endpoints /admin de la sección 4 del contrato API
Fecha	4 de septiembre de 2026

Este documento distingue requisitos confirmados, diseño propuesto, trabajo planificado y pendientes externos.

1. Objetivo

Definir controles que permitan demostrar que el backend cumple el contrato funcional, restringe operaciones según el rol, valida entradas, protege secretos, mantiene trazabilidad y puede desplegarse y recuperarse de forma controlada. En Fase 1 estos controles se planifican; los resultados se registrarán al recibir y ejecutar la versión vigente.

PLANIFICADO	39 casos de prueba base: 27 positivos y 12 negativos o transversales, además de pruebas unitarias, de contrato, integración, autorización, regresión y humo.
-------------	--

2. Niveles y alcance

Nivel	Propósito	Cadencia	Dependencia
Unitario	Servicios, reglas y validadores aislados.	Cada cambio	Código vigente.
Contrato	Método, ruta, rol, estado y estructura de respuesta.	Cada endpoint	Servidor local o doble HTTP.
Integración	API, persistencia e integraciones reales.	Cada sprint	Base y servicios de prueba.
Autorización	JWT y permisos admin, finance, ops y support.	Cada ruta protegida	Tokens controlados.
Negativa	Entradas inválidas y reglas de negocio.	Cada operación con entrada	Datos diseñados.
Regresión	Flujos críticos y defectos corregidos.	Fin de sprint y release	Ambiente de pruebas.
Humo	Inicio, configuración y endpoints críticos.	Cada despliegue	Ambiente desplegado.

3. Pruebas negativas mínimas

- Credenciales inválidas y respuesta contractual de autenticación.
- Solicitud sin token o con token inválido.
- Rol sin autorización suficiente y respuesta 403.
- Path o identificador inexistente.
- Campos obligatorios ausentes, tipos incorrectos y valores fuera de rango.
- Paginación y filtros inválidos.
- Conflictos o reglas de negocio incumplidas.
- Importación de preguntas con formato inválido o parcialmente rechazado.
- Dependencia de datos o servicio no disponible.
- Operación de contenedor rechazada o no encontrada.
- Límite de solicitudes o suscripciones cuando el contrato lo establezca.
- Protección frente a datos sensibles en errores y registros.

4. Seguridad

Control	Aplicación	Evidencia prevista
Identidad	Credenciales solo por canal seguro y tokens con ciclo de vida definido.	Casos de login y expiración.
Autorización	Denegar por defecto y aplicar rol por ruta.	Matriz de roles y pruebas 401/403.
Validación	Validar antes de ejecutar lógica o persistencia.	Casos inválidos y código de error.
Secretos	Injectar desde el entorno; nunca documentarlos ni versionarlos.	Escaneo y revisión de configuración.
Datos	Usar datos ficticios en pruebas y limitar exposición.	Revisión de payloads y fixtures.
Auditoría	Registrar operaciones administrativas sensibles.	Eventos trazables y sin secretos.
Dependencias	Revisar versiones y vulnerabilidades al recibir manifiestos.	Inventario y reporte vigente.

5. Gestión de defectos

Un defecto se registrará solo después de reproducirlo en la versión vigente. Cada registro debe indicar caso, versión, pasos, resultado esperado, resultado real, severidad, responsable, evidencia y estado. La hoja de defectos permanece vacía y marcada NO_EVALUADO hasta que comience la ejecución.

Gate	Criterio mínimo
Fin de sprint	Historias aceptadas; pruebas relevantes aprobadas; defectos críticos cerrados; trazabilidad y documentación actualizadas.
Candidato a release	Contrato completo; regresión aprobada; seguridad revisada; configuración y secretos controlados; manual listo.
Producción	Despliegue y rollback ensayados; responsables y monitoreo definidos; aprobación registrada.
Cierre	Evidencia consolidada; demo reproducible; pendientes y lecciones documentados.

6. Ambientes y automatización

Se espera disponer de entornos de desarrollo, pruebas y producción. Las herramientas de pruebas y automatización se seleccionarán a partir del repositorio vigente. La capacidad deseada incluye ejecución automática por cambio, reporte de resultados, protección de secretos y gate antes del release; no se afirma que exista actualmente un pipeline o un mecanismo de empaquetado concreto.

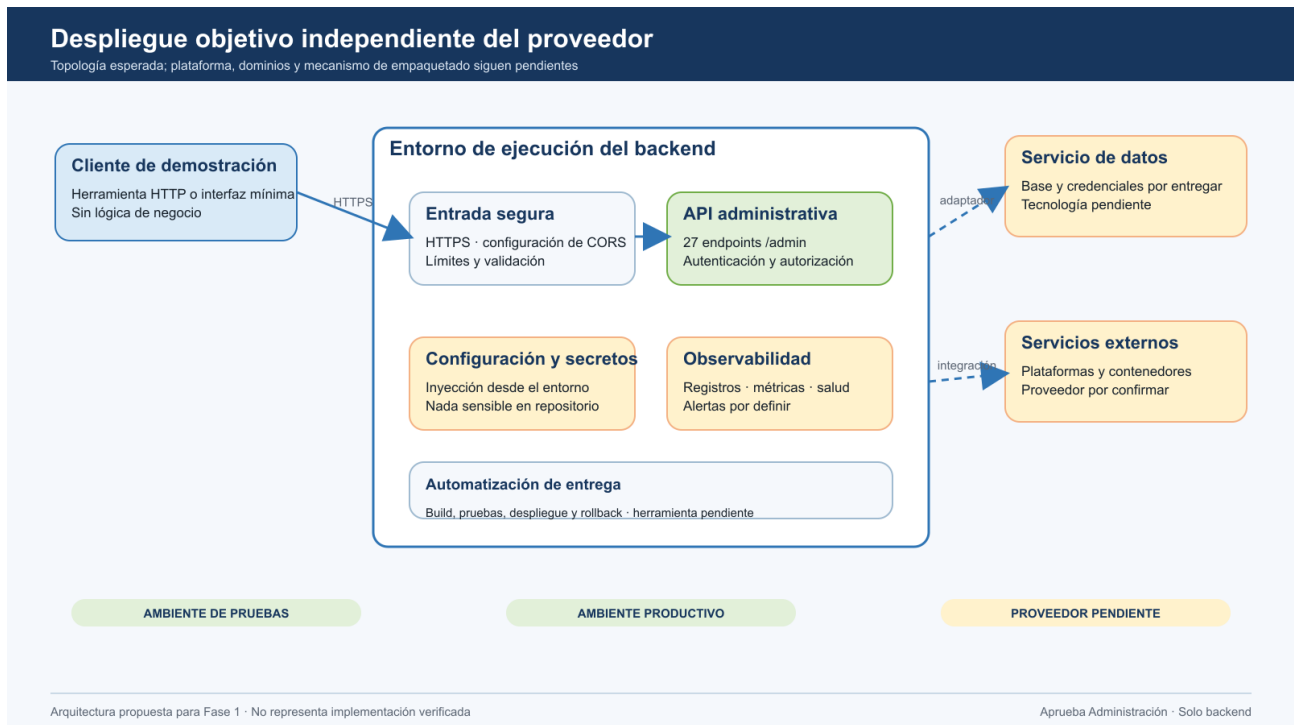


Figura 1. Despliegue objetivo; proveedor y mecanismo concreto pendientes.

7. Evidencias

- Registro de ejecución de pruebas con fecha y versión.
- Reporte por endpoint y matriz de cobertura.
- Registro de defectos reproducibles.
- Checklist de seguridad, repositorio y secretos.
- Registros de despliegue, humo, rollback y monitoreo.
- Aprobación del docente o contraparte cuando corresponda.

Referencias

- Aprueba. (2026). Especificación de API del backend, versión 1.0 [Documento técnico interno].
- Schwaber, K., & Sutherland, J. (2020). La guía de Scrum. <https://scrumguides.org/docs/scrumguide/v2020/2020-Scrum-Guide-Spanish-Latin-South-American.pdf>
- National Institute of Standards and Technology. (2022). Secure software development framework (SSDF) version 1.1 (NIST SP 800-218). <https://doi.org/10.6028/NIST.SP.800-218>
- OWASP Foundation. (2025). OWASP application security verification standard 5.0.0. <https://owasp.org/www-project-application-security-verification-standard/>